

Authority for Personal Data
 P.O. Box 93374, 2509 AJ The Hague
 Bezuidenhoutseweg 30, 2594 AV The Hague
 T 070 8888 500 - F 088-0712140
 autoriteitpersoonsgegevens.nl
 Confidential/Registered
 International Card Services B.V.
 P.O. Box 23225
 1100 DS DIEMEN
 Attention: Management
 Date

December 18, 2023

Our reference

[CONFIDENTIAL]

Contact person

[CONFIDENTIAL]

Subject

Decision to impose an administrative fine for violating the General Data Protection Regulation

Dear members of the management,

The Authority for Personal Data (AP) has decided to impose an administrative fine of €150,000 (one hundred fifty thousand euros) on International Card Services B.V. (ICS) for violating Article 35, paragraph 1, of the General Data Protection Regulation (GDPR). This is because ICS failed to conduct a Data Protection Impact Assessment (DPIA).

This decision explains the administrative fine. It will successively address the background and process, the established facts, the violation, and the amount of the fine. Finally, the ruling will follow.

Date

December 18, 2023

Our reference

[CONFIDENTIAL]

2/20

1. Background of the Investigation

1. ICS is a company based in Amsterdam and is active in offering financial products, particularly the issuance of so-called debit and credit cards.¹

2. The Customer Contact and Supervisory Research department of the AP initiated an investigation into a possible violation of the GDPR by ICS following signals and complaints from consumers about ICS. These complaints and signals were received by the AP after ICS began re-identifying its customers online in 2019 with the 'identification and verification process' (ID&V;).

3. The purpose of the investigation was to determine whether ICS complied with the rules set out in Article 35 of the GDPR when it did not conduct a DPIA in preparation for the ID&V; process.

2. Findings of the Research Report and Process

4. The findings of the investigation are laid out in a report.² It follows from this that the implementation of ID&V; involved the processing of personal data that likely poses a high risk to the rights and freedoms of natural persons. ICS should have conducted a DPIA prior to the processing. The report concluded that ICS failed to conduct a DPIA. Thus, it acted in violation of Article 35, paragraph 1, of the GDPR, according to the report.

5. The report was signed on June 23, 2022, and sent to ICS on July 7, 2022.³ ICS provided its comments on the report on September 14, 2022. On October 20, 2022, ICS orally explained its

comments.

6. The AP posed additional written questions to ICS on December 2, 2022, and February 13, 2023, to which ICS responded on December 21, 2022, and March 24, 2023, respectively.

3. Legal Framework

7. For better readability of this decision, the relevant legal framework is included in Annex 1. The legal framework is part of this decision.

1 Annex 21 to the research report.

2 Research report of June 23, 2022.

3 File document 1.

Date

December 18, 2023

Our reference

[CONFIDENTIAL]

3/20

4. Position of ICS

8. ICS has provided the following position on the report.

9. ICS has established an extensive risk process, called the Change Risk Assessment (CRA process). The CRA process identifies, mitigates, and monitors risks. A Privacy Impact Assessment is part of the CRA process, and a DPIA is conducted when warranted.

10. ICS is a 100% subsidiary of ABN AMRO. Since 2015, ABN AMRO has been using an application from Mitek Systems B.V. (Mitek app) to verify the identity of its customers. ABN AMRO also uses the CRA process to analyze risks, and for the use of the Mitek app, ABN AMRO has conducted a comprehensive analysis of the use of the Mitek app. ICS has utilized the same technology to re-identify its customers. For ICS, there was no reason to conduct a new analysis, as ABN AMRO had already performed one.

11. ICS further argues that it has investigated whether additional measures should be included in the CRA process for ID&V.; A Privacy Officer was involved at an early stage, and the nature and purpose of ID&V; were determined. It was also established which personal data is processed, who has access to this personal data, what retention periods apply, whether there is any transfer outside the EU, and the measures taken for such transfers.

12. Moreover, ICS asserts that at the introduction of ID&V;, there was no high risk of misuse of personal data. The personally identifiable information used in ID&V; is not inherently sensitive and is necessary to comply with legal requirements. When processing the citizen service number, the highest level of security applies, which is also based on legislation from the financial sector. Furthermore, strict requirements are imposed on encryption, the use of secure connections, conducting penetration tests, and the audit requirements for the control of personal data when collaborating with third parties.

13. ICS has acknowledged that the PIA triage of August 28, 2018, incorrectly concluded that there was no large-scale processing of personal data. The PIA form has been amended since 2020 to prevent such an error from occurring again.

14. According to ICS, there is no power imbalance between its customers and ICS. ICS is legally required to identify its customers, who have the option to identify themselves non-digitally, and a credit card is not an essential payment service.

Date

December 18, 2023

Our reference

[CONFIDENTIAL]

4/20

15. The Data Protection Officer (DPO) of ICS has been indirectly involved in data protection risks through the Privacy Officer. ICS has not clearly communicated this circumstance previously.

16. The Decision regarding the list of processing activities for which a DPIA is mandatory provides a number of criteria, and according to ICS, only one criterion, namely large-scale processing, is applicable in this case. To conclude that a processing activity is likely to pose a high risk to the individuals concerned, two elements mentioned in the Decision must be present. Since this was not the case, ICS was not obliged to conduct a DPIA. Furthermore, the mentioned decision was published after the start of the implementation of ID&V.;

5. Assessment

5.1

Data Controller and Competence of the AP

17. It is established and undisputed that ICS is the data controller (Article 4, introductory part and under 7, GDPR) and that the AP is the competent supervisory authority (Article 56, first paragraph, GDPR).

5.2

Obligation to Conduct DPIA

18. The GDPR states, in summary, that a DPIA must be conducted prior to processing when that processing is likely to result in a high risk to the rights and freedoms of natural persons (Article 35, first paragraph, GDPR).

19. The Guidelines WP 248 rev. 014 (hereinafter: the Guidelines) describe the criteria applicable to the question of whether a DPIA must be conducted. The AP has established the Decision regarding the list of processing activities of personal data (the Decision) considering the provisions in the GDPR (Article 35) and the aforementioned Guidelines. This decision states, among other things, that a DPIA is mandatory for the processing of biometric data.

20. It is undisputed that ICS did not conduct a DPIA prior to the implementation of ID&V; in 2018. The obligation to conduct a DPIA directly follows from Article 35, first paragraph, GDPR, read in conjunction with the aforementioned Guidelines. The fact that the Decision was only established and published by the AP on November 27, 2019, does not mean that ICS was not required to conduct a DPIA for that reason. The Decision contains requirements that are also mentioned in the GDPR and the Guidelines and stem from them.

4 Guidelines for Data Protection Impact Assessments and determining whether a processing activity “is likely to result in a high risk” within the meaning of Regulation 2016/679 (WP 248 rev. 01). The EDPB has endorsed these Guidelines.

5 Decision on the list of processing activities of personal data for which a Data Protection Impact Assessment (DPIA) is mandatory, by the Authority for Personal Data of November 19, 2019, Stcrt. 2019, 64418. This decision is based on the GDPR and the Guidelines WP 248 rev. 01.

Date

December 18, 2023

Our reference

[CONFIDENTIAL]

5/20

21. The first question that must be answered in this case is whether there is a type of processing that likely poses a high risk to the rights and freedoms of natural persons. If this is the case, ICS has the obligation to conduct a DPIA prior to the implementation of ID&V.;

22. A processing operation is generally considered to likely pose a high risk to the rights and freedoms of natural persons when two (of the nine) criteria listed in the Guidelines are met. In this case, three criteria listed in the Guidelines apply. These are: 1) sensitive data or data of a highly personal nature; 2) data processed on a large scale; and 3) data concerning vulnerable data subjects.

23. It has been established that for ID&V, the first and last name, date of birth, place of birth, address details, email address, phone number, gender, BSN, ID document number, as well as the photo therein and a (liveness) photo of a data subject are processed.⁶ These personal data are, as follows from the Guidelines,⁷ to be regarded collectively as sensitive data and data of a highly personal nature.

24. Furthermore, it has been established that ICS has approximately 1.5 million customers in the Netherlands who have had to re-identify themselves, and whose data ICS retains for as long as a data subject remains a customer of ICS.⁸ In the opinion of the AP, this means that there is also large-scale processing of personal data.

25. Contrary to what is described in the research report, upon further examination of the facts, the AP is of the opinion that there are no vulnerable data subjects whose personal data are being processed in this case. Vulnerable data subjects can be children, but also employees or a segment of the population that requires special protection, as follows from the Guidelines.⁹ It concerns the fact that there is an imbalanced relationship between data subjects and the data controller. In this context, ICS has rightly argued that a credit card is not an essential financial product for the daily life of a data subject. A credit card does not serve the function of a bank account and is therefore not comparable. This means that there is no imbalanced relationship between ICS and its customers, and therefore customers of ICS cannot be classified as vulnerable data subjects as described in the Guidelines. Moreover, it is not excluded that other credit card providers may employ different methods for identifying their customers. Thus, data subjects interested in a credit card have the choice to use the services of other providers.

6 Appendix 3, p. 5, research report.

7 Guidelines mentioned, p. 11.

8 Appendix 3, p. 4, research report.

9 Guidelines mentioned, p. 12.

Date

December 18, 2023

Our reference

[CONFIDENTIAL]

6/20

26. Now that at least two criteria from the Guidelines are applicable, there is a type of processing that likely poses a high risk to the rights and freedoms of natural persons. This means that conducting a DPIA by ICS was mandatory.

27. According to ICS, it was not required to conduct a DPIA because the CRA process analyzed risks of misuse of personal data, and this process is, in ICS's view, comparable to a DPIA. The subsequent question that must be answered in light of this is whether ICS's CRA process can be equated with a DPIA.

28. The AP rules as follows. The Guidelines provide criteria for an acceptable DPIA (not to be confused with criteria for assessing whether a DPIA must be conducted). It is then up to a data controller to choose a method that meets the established criteria. The data controller is obliged to comply with those (main and sub) criteria. Thus, it must:

1. provide a systematic description of the processing;
2. assess the necessity and proportionality of the processing;
3. manage the risks to the rights and freedoms of data subjects;
4. involve stakeholders (their representatives) and the data protection officer (DPO). For example, the advice of the DPO must be sought, or the opinions of data subjects must be requested.

29. ICS has utilized the CRA process of ABN-AMRO. The CRA process of ABN-AMRO consists of 22 risks (threats) with an associated code. The vast majority of the described risks directly or indirectly relate to fraud prevention and compliance with the Act on the Prevention of Money Laundering and

Financing of Terrorism (Wwft). Only three risks (risk key r007, r011, r025) pertain to the protection of personal data. Thus, ICS meets one of the main criteria from the Guidelines mentioned in paragraph 28, namely the third criterion: "management of risks to the rights and freedoms of data subjects." The CRA process of ABN-AMRO was insufficiently focused on the protection of personal data concerning the other three criteria, so the CRA process is not comprehensive enough to comply with the GDPR.

30. In addition to the CRA process of ABN-AMRO, ICS conducted its own CRA process in April 2020. This CRA process also does not provide a systematic description of the processing. Furthermore, it has not been demonstrated that the necessity and proportionality of the processing have been assessed, particularly the measures that contribute to the protection of the rights of data subjects. Moreover, it has not been shown that stakeholders, their representatives, or the data protection officer were involved in the processing. For instance, the DPO of ICS was unable to provide advice on conducting a DPIA. This means that ICS has not assessed three of the four (main) criteria for an acceptable DPIA.

31. From the above, it follows that the criteria mentioned in the Guidelines for an acceptable DPIA have not been applied in ICS's CRA process. In the opinion of the AP, the CRA processes of ICS and ABN-AMRO cannot therefore be equated with a DPIA. The CRA processes of ICS and ABN-AMRO were primarily aimed at preventing and combating (identity) fraud and did not specifically focus on the protection of personal data.

32. Moreover, the Privacy Impact Assessment triage of June 18, 2019, as part of the CRA process, did not result in a DPIA being conducted because it incorrectly did not recognize that it concerns large-scale processing.

33. The AP is of the opinion that ICS should have conducted a DPIA. By failing to do so, ICS has violated Article 35, paragraph 1, GDPR. The AP sees reason to impose a fine.

6. Administrative fine

34. The AP is authorized to impose an administrative fine based on Article 58, paragraph 2, introductory phrase and under i, in conjunction with Article 83 GDPR and read in conjunction with Article 14, paragraph 3, UAVG.

35. It has been concluded in paragraph 33 that ICS wrongfully did not conduct a DPIA and thereby violated Article 35, paragraph 1, GDPR. This means that there is one act for which a fine will be imposed.

6.1

Determining the fine amount

36. In exercising the authority to impose an administrative fine, the AP takes into account both the Policy Rules of the AP regarding the determination of the amount of administrative fines (Stcrt. 2019, 14 586) (hereinafter: Fine Policy Rules) and the Guidelines on the calculation of administrative fines under the GDPR (hereinafter: Guidelines). This is in accordance with what is stated in the explanation of the Fine Policy Rules regarding the establishment of joint principles concerning the calculation of fines and the temporary nature of the AP's policy on this matter.

13 Appendix 3, p. 12, research report.

14 Currently, no Dutch translation of the Guidelines is available. The Guidelines can be consulted at .
Date

December 18, 2023

Our reference

[CONFIDENTIAL]

8/20

37. The penalty amount will be determined as follows:

1.

Determining the starting amount of the penalty based on the Penalty Policy Rules 2019;

2. Considering the circumstances based on the Penalty Policy Rules;
3. Considering the circumstances based on the Guidelines;
4. Establishing the penalty amount and assessing effectiveness, proportionality, and deterrence.

38. These components will be addressed in succession below.

6.2

Determining the starting amount based on the Penalty Policy Rules 2019

39. As mentioned above, the starting point in this case is formed by the applicable range of the Penalty Policy Rules. The AP, when determining the amount of the penalty, takes into account the factors mentioned in Article 7 of the Penalty Policy Rules, without prejudice to Articles 3:4 and 5:46 of the General Administrative Law Act (Awb). These factors are also mentioned in Article 83, second paragraph, of the General Data Protection Regulation (GDPR) and in the Guidelines.

40. For a violation of Article 35, first paragraph, of the GDPR, the AP can impose an administrative fine of up to €10,000,000. In the case of a company, a fine can be imposed of up to 2% of the total global annual turnover in the previous financial year, if this figure is higher. The AP determines that the total global annual turnover of the parent company of ICS in 2022 amounts to €7.841 billion, and therefore the legal maximum penalty amounts to €156.8 million.

41. Under the Penalty Policy Rules, a violation is classified into a category based on the provision violated, ranging from category I to IV. It holds that the more important the provision is for the protection of personal data, the higher the category of violation. The Penalty Policy Rules state that violations of Article 35, first paragraph, of the GDPR fall into category II. The range of this category is from €120,000 to €500,000, with a base fine of €310,000. This amount will be taken as the starting point for the further calculation of the final penalty, after consideration of the relevant factors.

6.3

Considering the circumstances based on the Penalty Policy Rules

42. In determining the amount of the penalty, the relevant circumstances in this case are assessed based on the factors mentioned in Article 7 of the Penalty Policy Rules.

15 A calculation based on the global turnover of €7.841 billion of ABN-AMRO, as the parent company of ICS. See according to the Integrated Annual Report ABN-AMRO 2022, p.237.

16 See Penalty Policy Rules 2019, Appendix 1.

Date

December 18, 2023

Our reference

[CONFIDENTIAL]

9/20

43. One of these factors is the severity of the violation. In determining this, account is taken of the nature, seriousness, and duration of the infringement. Other circumstances that are taken into account include the categories of personal data involved and whether the infringement is intentional or negligent in nature.

44. The following is relevant in this regard. The obligation to carry out a Data Protection Impact Assessment (DPIA) is intended to describe the process of processing personal data, so that not only the necessity and proportionality of the processing are mapped out, but also the risks to the rights and freedoms of data subjects in the processing of personal data. The failure to carry out a DPIA is therefore, in itself, already a violation of the GDPR, while it also increases the likelihood of new violations of the GDPR because risks of possible (other) infringements of the GDPR are not timely recognized.

45. For determining the severity of the violation, it is further relevant that ICS processes personal data of a large number of data subjects, namely 1.5 million customers. This fact contributes to the severity of the violation. The Dutch Data Protection Authority (AP) has classified the personal data processed by ICS as sensitive data and data of a very personal nature. At the same time, the AP takes into account the circumstance that ICS has initiated the process of re-identifying its customers based on obligations arising from the Anti-Money Laundering and Anti-Terrorist Financing Act (Wwft). In complying with this, the AP has not found that ICS intentionally failed to carry out the required DPIA. However, in the AP's opinion, negligence is present. The failure to carry out a DPIA is due to a misjudgment by ICS. They have used fraud prevention and compliance with the Wwft as guiding principles, but in that context, ICS should also have independently assessed compliance with the GDPR. The AP weighs the element of negligence in this case as "neutral," because it cannot be said that ICS was entirely non-compliant by not carrying out a DPIA, in which context the AP attaches significance to the circumstance that ICS does comply with one of the main criteria from the aforementioned Guidelines for an acceptable DPIA in the application of the CRA process, namely the management of risks to the rights and freedoms of data subjects. To that extent, ICS has indeed paid (some) attention to the aforementioned risks that may arise in the processing of personal data.

46. It has been established that ICS wrongly did not carry out a DPIA. In determining the severity of the violation, the AP does take into account the circumstance that ICS carried out the aforementioned CRA process at the start of re-identifying its customers. Part of that process is, as ICS has indicated in its opinion, a Privacy Impact Assessment, in which a Privacy Officer is involved. In that assessment, it has been established which personal data are processed, who has access to this personal data, what retention periods apply, and whether there is any transfer outside the EU and the measures that have been taken for this transfer. As the AP has also considered earlier, ICS has been aware of the risks to the rights and freedoms of data subjects in the processing of personal data, but has insufficiently recognized that this should have led to the carrying out of a DPIA.

Date

December 18, 2023

Our reference

[CONFIDENTIAL]

10/20

47. The AP has taken into consideration the other circumstances mentioned in Article 7, introductory phrase and under k, Fine Policy Rules. The AP has included as other circumstances the long time frame between the publication of the investigation report and the issuance of an enforcement decision. This aspect has been regarded as a mitigating factor regarding the amount of the fine.

48. Furthermore, no other circumstances have been found that are mentioned in Article 7 of the Fine Policy Rules and have occurred concerning the infringement by ICS.

49. Considering the above circumstances, the AP is of the opinion that in this case the severity of this infringement should be classified as low.

6.4

Consideration of the circumstances based on the Guidelines

50. The European Data Protection Board (EDPB) established the final text of the Guidelines on May 24, 2023. As mentioned above, the EDPB has established joint principles regarding the calculation of fines for violations of the GDPR.

51. The Guidelines describe a methodology in which the following steps are sequentially considered:

1. Which and how many actions and violations are under assessment;
2. What starting amount serves as the basis for calculating the fine for this;
3. Whether there are mitigating or aggravating circumstances that necessitate an adjustment of the amount from step 2;

4. What maximum amounts apply for the violations and whether any increases from the previous step do not exceed this amount;
5. Whether the final amount of the calculated fine meets the requirements of effectiveness, deterrence, and proportionality, and if necessary, is adjusted accordingly.

52. The number of actions that resulted in violations of the GDPR and the starting amount for fine calculation have already been qualified under paragraph 6.2.

53. Like the Fine Policy Rules, the Guidelines stipulate that the AP examines whether there are mitigating or aggravating circumstances that may lead to an adjustment in the qualification of the infringement. This should be done based on the circumstances mentioned in Article 83, second paragraph, introductory phrase and under a to k, GDPR.

Date

December 18, 2023

Our reference

[CONFIDENTIAL]

11/20

54. First of all, attention must be paid to the severity of the infringement.¹⁷ This takes into account the nature, seriousness, and duration of the infringement, as well as the intentional or negligent nature of the infringement and the categories of personal data processed. These factors have already been discussed in paragraphs 43 to 46. This has led to the conclusion in paragraph 49 that the seriousness of the infringement is classified as not low.

55. The Guidelines stipulate that, from the perspective of fairness, the size of the company must be taken into account when calculating the amount of the fine. The size of the company is determined based on revenue. According to the case law¹⁸ of the Court of Justice of the European Union, the revenue of the entire group must be used to determine the upper limit of the fine. ICS is a wholly-owned subsidiary of ABN-AMRO. Therefore, the size of the company will be determined based on the global revenue of ABN-AMRO.¹⁹ ABN-AMRO achieved a revenue of €7.841 billion in 2022. Since ABN-AMRO's revenue exceeds €156.8 million, the GDPR prescribes a maximum fine of 2% of the total global annual revenue.²⁰

56. Subsequently, the Guidelines prescribe that the other circumstances referred to in Article 83 GDPR are taken into account. As already mentioned, sections c to f and sections h to j of Article 7 of the Fine Policy Rules were found to be irrelevant in the case of ICS. These sections correspond to the prescribed elements that must be considered under the Guidelines and are therefore not relevant in the case of ICS.

57. The AP has taken into account the other circumstances as mentioned in Article 7, introductory part and under k, of the Fine Policy Rules. This provision corresponds to Article 83, paragraph 2, introductory part and under k, GDPR. The AP has considered the long time frame between the publication of the investigation report and the issuance of an enforcement decision as an additional circumstance. This aspect is noted as mitigating regarding the amount of the fine in paragraph 6.2.

6.5

Determining the amount of the fine and assessing effectiveness, proportionality, and deterrence

58. In this case, however, the amount of the fine will be determined using the base fine from the relevant category of the Fine Policy Rules. Moreover, as outlined above, in this specific case, the amount of the fine will lead to the same outcome based on both the Fine Policy Rules and the Guidelines.

59. This case involves an infringement where category II of the Fine Policy Rules is applicable. The fine range for category II is between €120,000 and €500,000.

¹⁷ Guidelines, p. 17.

¹⁸ Groupe Gascogne SA/European Commission (Case C-58/12P, judgment of November 26, 2013),

ECLI:EU:C:2013:770, § 52-57.

19 A calculation based on the global revenue of €7.841 billion of ABN-AMRO, as the parent company of ICS. See according to the Integrated Annual Report ABN-AMRO 2022, p.237.

20 See Article 83 paragraph 5 of the GDPR.

Date

December 18, 2023

Our reference

[CONFIDENTIAL]

12/20

60. Finally, it must be assessed whether the fine is effective, proportionate, and deterrent. Based on Article 49 of the Charter of Fundamental Rights of the EU, the administrative fine, considering the circumstances of the specific case, must not lead to a disproportionate outcome. This is also laid down in Articles 3:4 and 5:46, second paragraph, of the General Administrative Law Act (Awb).

61. Based on Article 83, paragraph 5, introductory part and under b, GDPR, the AP may impose an administrative fine for the violations described above. The purpose of imposing an administrative fine may lie in both punishing unlawful conduct and promoting compliance with applicable regulations.

62. Considering the nature, seriousness, and duration of the infringement, as well as the other factors from Article 83, paragraph 2, GDPR as assessed in this chapter, imposing an administrative fine under these circumstances has an effective and deterrent effect. Furthermore, it has not been shown that the infringement cannot be attributed to ICS.

63. Given all the circumstances mentioned above, the AP concludes that a fine of €150,000 for the infringement of not conducting a DPIA (Article 35, paragraph 1, GDPR) is appropriate and warranted in this case.

7. Decision

64. The AP imposes an administrative fine of €150,000 (say: one hundred fifty thousand euros) on International Card Services B.V. for violating Article 35, paragraph 1, GDPR.²¹

Yours sincerely,

Dutch Data Protection Authority,

w.g.

mr. A. Wolfsen

Chairman

21 The AP will refer the aforementioned claim to the Central Judicial Collection Agency (CJIB).

Date

December 18, 2023

Our reference

[CONFIDENTIAL]

13/20

Remedies Clause

If you disagree with this decision, you may submit a notice of objection digitally or on paper to the Authority for Personal Data within six weeks of the date of dispatch of the decision. Pursuant to Article 38 of the GDPR, the submission of a notice of objection suspends the effect of the order imposing the administrative fine. The AP will only proceed to collection after the decision has become irrevocable. For submitting a digital objection, see www.autoriteitpersoonsgegevens.nl, under the heading Making an Objection to a Decision, at the bottom of the page under the heading Contact with the Authority for Personal Data. The address for submitting on paper is: Authority for Personal Data, P.O. Box 93374, 2509 AJ The Hague.

Please indicate on the envelope 'Awb-objection' and include 'notice of objection' in the title of your

letter.

Your notice of objection must include at least:

- your name and address;
- the date of your notice of objection;
- the reference mentioned in this letter (case number); or attach a copy of this decision;
- the reason(s) why you disagree with this decision;
- your signature.

Date

December 18, 2023

Our reference

[CONFIDENTIAL]

14/20

Annex 1

General Data Protection Regulation

Article 4

Definitions

For the purposes of this regulation, the following definitions apply:

1) "personal data": any information relating to an identified or identifiable natural person ("the data subject"); an identifiable natural person is one who can be identified, directly or indirectly, particularly by reference to an identifier such as a name, an identification number, location data, an online identifier, or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person;

[...]

Article 9

Processing of special categories of personal data

1. Processing of personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, and processing of genetic data, biometric data for the purpose of uniquely identifying a person, or data concerning health, or data concerning a person's sexual behavior or sexual orientation is prohibited.

2. Paragraph 1 does not apply where one of the following conditions is met:

a)

the data subject has given explicit consent to the processing of those personal data for one or more specified purposes, except where Union law or Member State law provides that the prohibition in paragraph 1 may not be lifted by the data subject;

b)

the processing is necessary for the performance of obligations and the exercise of specific rights of the data controller or the data subject in the field of employment law and social security and social protection law, insofar as permitted by Union law or Member State law or by a collective agreement under Member State law that provides appropriate safeguards for the fundamental rights and the legitimate interests of the data subject;

c)

the processing is necessary to protect the vital interests of the data subject or of another natural person where the data subject is physically or legally incapable of giving consent;

Date

December 18, 2023

Our reference

[CONFIDENTIAL]

15/20

d) the processing is carried out by a foundation, an association, or another non-profit entity that operates in the political, philosophical, religious, or trade union field, within the framework of its

legitimate activities and with appropriate safeguards, provided that the processing relates solely to the members or former members of the entity or to persons who regularly have contact with it in relation to its purposes, and that the personal data are not disclosed outside that entity without the consent of the data subjects;

e) the processing relates to personal data that have been manifestly made public by the data subject;

f) the processing relates to personal data that have been manifestly made public by the data subject;

g) the processing is necessary for reasons of substantial public interest, based on Union law or the law of a Member State, ensuring that the proportionality with the pursued objective is guaranteed, the essential content of the right to the protection of personal data is respected, and appropriate and specific measures are taken to protect the fundamental rights and interests of the data subject;

h) the processing is necessary for purposes of preventive or occupational medicine, for the assessment of the employee's fitness for work, medical diagnoses, the provision of health care or social services or treatments, or the management of health care systems and services or social systems and services, based on Union law or the law of a Member State, or under a contract with a health professional and subject to the conditions and safeguards mentioned in paragraph 3;

i) the processing is necessary for reasons of public interest in the area of public health, such as protection against serious cross-border threats to health or ensuring high standards of quality and safety of health care and of medicines or medical devices, based on Union law or the law of a Member State that includes appropriate and specific measures for the protection of the rights and freedoms of the data subject, in particular the professional secrecy;

j) the processing is necessary for archiving purposes in the public interest, scientific or historical research, or statistical purposes in accordance with Article 89, paragraph 1, based on Union law or the law of a Member State, ensuring that the proportionality with the pursued objective is guaranteed, the essential content of the right to the protection of personal data is respected, and appropriate and specific measures are taken to protect the fundamental rights and interests of the data subject.

3. The personal data referred to in paragraph 1 may be processed for the purposes mentioned in paragraph 2, point h), when those data are processed by or under the responsibility of a professional bound by professional secrecy under Union law or the law of a Member State or under rules established by national competent authorities, or by another person who is also bound to confidentiality under Union law or the law of a Member State or under rules established by national competent authorities.

Date

December 18, 2023

Our reference

[CONFIDENTIAL]

16/20

4. Member States may maintain or introduce additional conditions, including limitations, regarding the processing of genetic data, biometric data, or data concerning health.

Article 35

Data Protection Impact Assessment

1. When a type of processing, in particular processing that uses new technologies, is likely to result in a high risk to the rights and freedoms of natural persons, the controller shall carry out an assessment of the impact of the intended processing activities on the protection of personal data prior to the processing. One assessment may cover a series of similar processing operations that present similar high risks.

2. When a data protection officer has been designated, the controller shall seek the advice of the data protection officer when carrying out a data protection impact assessment.

3. A data protection impact assessment as referred to in paragraph 1 is particularly required in the following cases:

a) a systematic and extensive evaluation of personal aspects relating to natural persons, based on automated processing, including profiling, and on which decisions are based that produce legal effects

concerning the natural person or similarly significantly affect the natural person;

b) large-scale processing of special categories of personal data as referred to in Article 9, paragraph 1, or of personal data relating to criminal convictions and offenses as referred to in Article 10; or

c) systematic and large-scale monitoring of publicly accessible areas.

[...]

Article 58

Powers

[...]

2. Each supervisory authority shall have all of the following powers to impose corrective measures:

[...]

i) depending on the circumstances of each case, impose an administrative fine in addition to or instead of the measures referred to in this paragraph, based on Article 83;

Date

December 18, 2023

Our reference

[CONFIDENTIAL]

17/20

[...]

Article 83

General conditions for the imposition of administrative fines

1. Each supervisory authority ensures that the administrative fines imposed under this article for the infringements mentioned in paragraphs 4, 5, and 6 of this regulation are effective, proportionate, and dissuasive in each case.

2. Administrative fines are imposed, depending on the circumstances of the specific case, in addition to or instead of the measures referred to in Article 58, paragraph 2, points a) to h) and j). In deciding whether to impose an administrative fine and determining its amount, the following shall be duly considered for each specific case:

a) the nature, seriousness, and duration of the infringement, taking into account the nature, scope, or purpose of the processing in question as well as the number of affected data subjects and the extent of the damage suffered by them;

b) the intentional or negligent nature of the infringement;

c) the measures taken by the data controller or the processor to mitigate the damage suffered by data subjects;

d) the degree of responsibility of the data controller or the processor, considering the technical and organizational measures they have implemented in accordance with Articles 25 and 32;

e) previous relevant infringements by the data controller or the processor;

f) the degree to which the data controller or the processor has cooperated with the supervisory authority to remedy the infringement and mitigate its possible negative effects;

g) the categories of personal data affected by the infringement;

h) the manner in which the supervisory authority became aware of the infringement, in particular whether, and if so to what extent, the data controller or the processor reported the infringement;

i) compliance with the measures referred to in Article 58, paragraph 2, insofar as they have previously been taken against the data controller or the processor in question regarding the same matter;

j) adherence to approved codes of conduct in accordance with Article 40 or approved certification mechanisms in accordance with Article 42; and

k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as financial gains made, or losses avoided, whether or not directly resulting from the infringement.

3. If a data controller or a processor intentionally or negligently infringes multiple provisions of this regulation concerning the same or related processing activities, the total fine shall not exceed that for the most serious infringement.

Date

December 18, 2023

4. Violations of the provisions below are subject to administrative fines of up to 10,000,000 EUR or, for an undertaking, up to 2% of the total global annual turnover in the preceding financial year, if this figure is higher:

- a) the obligations of the data controller and the processor in accordance with Articles 8, 11, 25 to 39, and 42 and 43;
- b) the obligations of the certification body in accordance with Articles 42 and 43;
- c) the obligations of the supervisory authority in accordance with Article 41, paragraph 4.

5. Violations of the provisions below are subject to administrative fines of up to 20,000,000 EUR or, for an undertaking, up to 4% of the total global annual turnover in the preceding financial year, if this figure is higher:

- a) the basic principles regarding processing, including the conditions for consent, in accordance with Articles 5, 6, 7, and 9;
- b) the rights of the data subjects in accordance with Articles 12 to 22;
- c) the transfers of personal data to a recipient in a third country or an international organization in accordance with Articles 44 to 49;
- d) all obligations established by law under Chapter IX by the Member States;
- e) non-compliance with an order or a temporary or permanent processing restriction or a suspension of data flows by the supervisory authority in accordance with Article 58, paragraph 2, or non-granting of access in violation of Article 58, paragraph 1.

6. Non-compliance with an order of the supervisory authority as referred to in Article 58, paragraph 2, is subject to administrative fines of up to 20,000,000 EUR or, for an undertaking, up to 4% of the total global annual turnover in the preceding financial year, if this figure is higher.

7. Without prejudice to the powers to take corrective measures of the supervisory authorities in accordance with Article 58, paragraph 2, each Member State may establish rules regarding whether and to what extent administrative fines can be imposed on public authorities and bodies established in that Member State.

8. The exercise by the supervisory authority of its powers under this Article is subject to appropriate procedural safeguards in accordance with Union law and national law, including effective judicial remedy and fair legal proceedings.

9. When the legal system of the Member State does not provide for administrative fines, this Article may be applied in such a way that fines are initiated by the competent supervisory authority and imposed by competent national courts, ensuring that these remedies are effective and have the same effect as the administrative fines imposed by supervisory authorities. The fines are in any case effective, proportionate, and dissuasive. Those Member States shall notify the Commission by May 25, 2018, of the legislative provisions they establish under this paragraph, as well as any subsequent amendments and all legislation affecting them.

Implementation Act General Data Protection Regulation

Article 14

Tasks and powers of the AP

[...]

3. The Data Protection Authority may impose an administrative fine of up to the amounts mentioned in paragraphs four, five, or six of the Regulation in the event of a violation of the provisions of Article 83.

General Administrative Law Act

Article 3:2

In preparing a decision, the administrative body gathers the necessary knowledge regarding the relevant facts and the interests to be weighed.

Article 3:4

1. The administrative body weighs the interests directly involved in the decision, insofar as no limitation

arises from a statutory provision or from the nature of the power to be exercised.

2. The adverse consequences of a decision for one or more stakeholders must not be disproportionate in relation to the objectives to be served by the decision.

Article 4:8

1. Before an administrative body issues a decision against which a stakeholder who did not request the decision is expected to have objections, it allows that stakeholder the opportunity to present their views if:

- a) the decision would be based on data about facts and interests that concern the stakeholder, and
- b) that data has not been provided by the stakeholder themselves.

2. The first paragraph does not apply if the stakeholder has not complied with a legal obligation to provide data.

Article 5:46

1. The law determines the administrative fine that may be imposed for a specific violation.

Date

December 18, 2023

Our reference

[CONFIDENTIAL]

19/20

2. Unless the amount of the administrative fine is established by statutory provision, the administrative body adjusts the administrative fine to the severity of the violation and the degree to which it can be attributed to the offender. The administrative body takes into account, if necessary, the circumstances under which the violation was committed.

3. If the amount of the administrative fine is established by statutory provision, the administrative body may still impose a lower administrative fine if the offender demonstrates that the established administrative fine is too high due to special circumstances.

4. Article 1, paragraph two, of the Penal Code applies *mutatis mutandis*.